

1. Resumen Ejecutivo

Este informe documenta los resultados de la auditoría de seguridad realizada al prototipo del Sistema de Control de Tráfico Marítimo (MaritimeVTS) del Terminal de Contenedores de Puerto Valparaíso (TCP Valparaíso). La auditoría evaluó el cumplimiento normativo respecto a la Ley 21.719 de Ciberseguridad de Chile, la Ley 19.628 de Protección de Datos Personales, el estándar internacional OWASP Top 10, ISO/IEC 27001, IEC 62443, NIST CSF 2.0 y la resolución IMO MSC.428(98) sobre gestión de riesgos cibernéticos en buques.

Se identificaron 26 hallazgos distribuidos en los siguientes niveles de severidad: **1 críticos**, **8 altos**, **11 medios**, **2 bajos** y **4 informativos**. El índice global de cumplimiento alcanzado es del 15%, lo que indica que el sistema se encuentra en estado de prototipo demostrativo y requiere trabajo significativo antes de su despliegue en un entorno operacional real o ante auditorías formales de Directemar o ANCI.

El análisis cubrió ocho dimensiones: (1) headers HTTP de seguridad, (2) secretos hardcodeados en código, (3) funciones peligrosas en código fuente, (4) autenticación y gestión de sesión, (5) seguridad de APIs, (6) protección de datos personales conforme a la Ley 19.628, (7) cumplimiento de la Ley 21.719 de Ciberseguridad incluyendo capacidad de respuesta a incidentes, y (8) análisis de vulnerabilidades en dependencias de terceros (SCA — Software Composition Analysis).

1.1 Distribución de Hallazgos por Severidad

Severidad	Cantidad	Estado
Crítica	1	Acción inmediata requerida
Alta	8	Resolver antes de producción
Media	11	Plan de remediación a 30 días
Baja	2	Plan de remediación a 90 días
Informativa	4	Documentar, sin acción
Total	26	—



Norma / Estándar	Estado	Hallazgos
Ley 21.719 (Ciberseguridad Chile)	15% cumplido	18
Ley 19.628 (Datos Personales)	Parcial	10
OWASP Top 10 (2021)	Parcial	9
ISO/IEC 27001 (SGSI)	Parcial	13
IEC 62443 (Industrial)	Parcial	5
NIST CSF 2.0	Parcial	7

IMO MSC.428(98)	Parcial	1
-----------------	---------	---

2. Hallazgos Detallados

A continuación se documentan los 26 hallazgos identificados durante la auditoría, ordenados por nivel de severidad (crítico → alto → medio → bajo → informativo). Cada hallazgo incluye descripción técnica, evidencia, recomendación de remediación y referencia normativa aplicable.

#01 CS_INCIDENT_NOTIFICATION	CRÍTICA	NO CUMPLE
------------------------------	---------	-----------

Notificación de incidentes a ANCI

Categoría: Ley 21.719 (Ciberseguridad)

Descripción: La Ley 21.719 Art. 16 obliga a notificar a la Agencia Nacional de Ciberseguridad (ANCI) cualquier incidente cibernético relevante dentro de las 3 horas siguientes a su detección. No existe procedimiento formal de notificación.

Evidencia:

Evidencia: Análisis de cumplimiento basado en revisión de arquitectura

Recomendación: Establecer canal seguro de comunicación con ANCI. Plantilla de notificación de incidentes. Persona responsable designada (CISO/DPO). Ejercicios simulacros de incidente al menos 2 veces al año.

Referencia normativa: Ley 21.719 Art. 16 · Ley 21.719 Art. 24

#02 API_CHAT_NO_AUTH	ALTA	NO CUMPLE
----------------------	------	-----------

API /api/chat sin autenticación

Categoría: API Security

Descripción: El endpoint /api/chat (asistente IA MarÍA) responde sin validar autenticación. Esto permite a cualquier atacante: (1) consumir tokens del LLM agotando cuota, (2) extraer información de la base TPS mediante prompts maliciosos, (3) ejecutar búsquedas web a través del VTS, (4) lanzar ataques de prompt injection.

Evidencia:

POST /api/chat → HTTP 200 sin Authorization header

Recomendación: Implementar middleware de autenticación + rate limiting + filtrado de input (validar que userQuery no contenga prompts maliciosos). Considerar implementar guardrails de prompt injection con un sistema de capas: (1) filtro de input, (2) LLM con system prompt reforzado, (3) filtro de output.

Referencia normativa: Ley 19.628 Art. 9 · Ley 21.719 Art. 24 · OWASP A03:2021 · ISO 27001 A.14

CWE: CWE-306: Missing Authentication for Sensitive Function

#03 API_NO_RATE_LIMIT

ALTA

NO CUMPLE

Sin rate limiting en APIs

Categoría: API Security

Descripción: No se implementa rate limiting en ningún endpoint API. Esto permite ataques de fuerza bruta, DoS, y abuso del LLM.

Evidencia:

Sin middleware de rate limiting detectado en src/app/api

Recomendación: Implementar rate limiting con upstash/ratelimit o express-rate-limit. Límites sugeridos: 60 req/min para APIs operacionales, 10 req/min para /api/chat (LLM), 5 req/hora para login.

Referencia normativa: Ley 21.719 Art. 24 · OWASP A07:2021 · NIST CSF PR.DS

CWE: CWE-770: Allocation of Resources Without Limits

#04 API_REPORTS_NO_AUTH

ALTA

NO CUMPLE

API /api/reports sin autenticación

Categoría: API Security

Descripción: El endpoint /api/reports responde a peticiones GET sin validar autenticación. Cualquiera con la URL puede generar y descargar informes operacionales del VTS, exponiendo datos de buques, arribos, alertas y KPIs.

Evidencia:

GET /api/reports → HTTP 200 (sin Authorization header, sin cookie de sesión)

Recomendación: Para producción: implementar middleware de Next.js que valide sesión NextAuth en todas las rutas /api/* (excepto /api/auth). Agregar verificación de rol (operador VTS, supervisor, etc.) y rate limiting (ej: 60 requests/minuto por usuario).

Referencia normativa: Ley 19.628 Art. 9 · Ley 21.719 Art. 24 · OWASP A01:2021 · IMO MSC.428(98)

CWE: CWE-306: Missing Authentication for Sensitive Function

#05 AUTH_REAL_OAUTH

ALTA

NO CUMPLE

Implementación real de OAuth (Microsoft/Google)

Categoría: Autenticación

Descripción: El prototipo simula el login con Microsoft 365 y Google Workspace mediante un setTimeout de 1200ms que crea un perfil mock. No hay validación real de credenciales ni intercambio de tokens OAuth 2.0 con Azure AD o Google.

Evidencia:

Código: src/store/auth-store.ts – función login() que retorna perfil predefinido tras await sleep(1200).

Recomendación: Para producción: instalar NextAuth.js v4 (ya en dependencias), configurar providers AzureAD y Google con client_id/client_secret reales desde variables de entorno. Implementar callback de verificación de email institucional y MFA obligatorio para operadores VTS.

Referencia normativa: Ley 21.719 Art. 24 · ISO 27001 A.9 · IEC 62443 SR 1.1-1.13

CWE: CWE-287: Improper Authentication

#06 CSIRT_TEAM**ALTA****NO CUMPLE****Equipo de Respuesta a Incidentes (CSIRT)**

Categoría: Ley 21.719 (Ciberseguridad)

Descripción: No existe un procedimiento formal de respuesta a incidentes. La Ley 21.719 Art. 24 exige que los Operadores de Importancia Vital (OIV) — los puertos lo son — dispongan de capacidad de respuesta a incidentes y notificación a la ANCI.

Evidencia:

Evidencia: Análisis de cumplimiento basado en revisión de arquitectura

Recomendación: Designar un CSIRT interno con roles definidos (incident commander, SOC analyst, comunicaciones). Definir matriz RACI para incidentes. Procedimientos de escalado a la Agencia Nacional de Ciberseguridad (ANCI) y al CSIRT Nacional.

Referencia normativa: Ley 21.719 Art. 24 · Ley 21.719 Art. 16

#07 CS_BACKUP**ALTA****NO CUMPLE****Estrategia de respaldo y recuperación**

Categoría: Ley 21.719 (Ciberseguridad)

Descripción: No se detecta estrategia de backup automatizada ni plan de recuperación ante desastres. La base SQLite se perdería completa ante un fallo del filesystem.

Evidencia:

Evidencia: Análisis de cumplimiento basado en revisión de arquitectura

Recomendación: Implementar backups automatizados: (1) DB snapshots diarios con retención 30 días, (2) replicación geográfica, (3) prueba de restauración trimestral, (4) RTO $\leq$ 4 horas y RPO $\leq$ 1 hora para sistemas críticos VTS.

Referencia normativa: Ley 21.719 Art. 24 · ISO 27001 A.12 · NIST CSF RC.RP

#08 DATA_ENCRYPTION_AT_REST**ALTA****NO CUMPLE****Cifrado en reposo de base de datos**

Categoría: Protección de Datos

Descripción: La base de datos SQLite (db/custom.db) se almacena sin cifrar en el sistema de archivos. Si un atacante obtiene acceso al filesystem, puede leer directamente todos los registros de buques, contenedores, logs de auditoría y datos del operador.

Evidencia:

Archivo: /home/z/my-project/db/custom.db (SQLite plano)

Recomendación: Para producción: (1) Migrar a PostgreSQL con cifrado a nivel de tabla (pgcrypto) o cifrado de volumen (LUKS en Linux). (2) Cifrar backups con AES-256. (3) Implementar key rotation. (4) Para datos personales muy sensibles: cifrado a nivel de columna.

Referencia normativa: Ley 19.628 Art. 9 · Ley 21.719 Art. 24 · ISO 27001 A.10 · IEC 62443 SR 3.1

CWE: CWE-311: Missing Encryption of Sensitive Data

Cifrado en tránsito (TLS)

Categoría: Protección de Datos

Descripción: El servidor de desarrollo (Next.js en puerto 3000) sirve contenido sin HTTPS. En producción debe configurarse TLS 1.3 obligatorio con HSTS, sin soporte para TLS 1.0/1.1.

Evidencia:

URL accesible: `http://localhost:3000` (HTTP plano, sin TLS)

Recomendación: Para producción: (1) Configurar TLS 1.3 con certificados válidos (Let's Encrypt o EV). (2) Habilitar HSTS con `max-age=63072000` (2 años) y `includeSubDomains`. (3) Configurar Caddy/Nginx para rechazar conexiones TLS 1.0/1.1. (4) Obtener calificación A+ en SSL Labs.

Referencia normativa: Ley 19.628 Art. 9 · Ley 21.719 Art. 24 · ISO 27001 A.10 · NIST CSF PR.DS-1 · IEC 62443 SR 3.1

Almacenamiento de credenciales en cliente

Categoría: Autenticación

Descripción: El store de autenticación usa persistencia (Zustand persist middleware) para guardar la sesión del usuario en `localStorage`. Esto expone los datos del usuario a scripts maliciosos en caso de un ataque XSS.

Evidencia:

Archivo: `src/store/auth-store.ts`

Patrón detectado: `memoria`

Recomendación: Para el prototipo esto es aceptable (no se almacenan credenciales, solo el perfil del usuario). Para producción: usar cookies `HttpOnly` + `Secure` + `SameSite=Strict` para el token de sesión, y nunca guardar contraseñas en el cliente. Implementar `NextAuth.js v4` con estrategia `JWT` en cookie `HttpOnly`.

Referencia normativa: Ley 19.628 Art. 9 · Ley 21.719 Art. 24 · ISO 27001 A.9

CWE: CWE-922: Insecure Storage of Sensitive Information

Evaluación de riesgos cibernéticos

Categoría: Ley 21.719 (Ciberseguridad)

Descripción: No existe un análisis formal de riesgos con metodología estándar (ISO 27005, NIST SP 800-30). Esta auditoría constituye el primer paso, pero debe formalizarse.

Evidencia:

Evidencia: Análisis de cumplimiento basado en revisión de arquitectura

Recomendación: Realizar evaluación formal anual con: (1) inventario de activos (datos, sistemas, procesos), (2) matriz de amenazas/vulnerabilidades, (3) cálculo de riesgo (probabilidad × impacto), (4) plan de tratamiento. Documentar y revisar trimestralmente.

Referencia normativa: Ley 21.719 Art. 24 · ISO 27001 A.8 (Risk Assessment) · NIST CSF ID.RA

#12 CS_SEGREGATION

MEDIA

PARCIAL

Segmentación de redes OT/IT

Categoría: Ley 21.719 (Ciberseguridad)

Descripción: En el prototipo no hay segmentación (es monolítico). En producción VTS real, la red OT (radares, AIS, cámaras) debe estar segregada de la red IT (dashboard, APIs) mediante firewall industrial (IEC 62443-3-3).

Evidencia:

Evidencia: Análisis de cumplimiento basado en revisión de arquitectura

Recomendación: Implementar zona DMZ entre IT y OT. Firewall industrial con deny-by-default. Solo protocolos necesarios (NTP, SNMP v3, RTSP) entre OT y VTS. Análisis de tráfico con IDS/IPS industrial.

Referencia normativa: IEC 62443-3-3 SR 5.1 · ISO 27001 A.13 · NIST CSF PR.AC-5

#13 DANG_1

MEDIA

PARCIAL

Función peligrosa: dangerouslySetInnerHTML

Categoría: Código Fuente

Descripción: Se detectó el uso de dangerouslySetInnerHTML en /src/components/ui/chart.tsx. Esta función puede introducir vulnerabilidades si recibe input del usuario sin sanitización.

Evidencia:

Patrón: dangerouslySetInnerHTML

Recomendación: Revisar el contexto de uso. Si recibe input del usuario, sanitizar estrictamente o reemplazar por alternativas seguras (DOMPurify para HTML, parámetros parametrizados para SQL).

Referencia normativa: OWASP A03:2021

CWE: CWE-79

#14 DATA_AUTH_STORE

MEDIA

PARCIAL

Tratamiento de datos personales: src/store/auth-store.ts

Categoría: Protección de Datos

Descripción: Se procesan los siguientes datos personales: name, email, organization, role. Base legal: Consentimiento (Art. 4 Ley 19.628). Falta implementar: (1) política de retención, (2) derecho de acceso/rectificación/cancelación (ARCO), (3) consentimiento explícito documentado, (4) registro de tratamiento ante el Registro de Bases de Datos (CPPD).

Evidencia:

Datos: name, email, organization, role

Base legal: Consentimiento (Art. 4 Ley 19.628)

Recomendación: Para producción: (1) Documentar el tratamiento en un Registro de Actividades de Tratamiento (RAT). (2) Implementar derechos ARCO mediante endpoint /api/privacy/* (acceso, rectificación, supresión, portabilidad). (3) Definir política de retención: logs de auditoría 5 años, sesiones 30 días. (4) Nombrar un Encargado de Protección de Datos si se supera el umbral de la ley.

Referencia normativa: Ley 19.628 Art. 2, 4, 9 · Ley 21.719 Art. 24

#15 HDR-CONTENT_SECURITY_POLICY

MEDIA

NO CUMPLE

Header HTTP: Content-Security-Policy

Categoría: Headers HTTP

Descripción: El header Content-Security-Policy NO está presente en las respuestas HTTP. Esto expone la aplicación a ataques como clickjacking, MIME-sniffing, o fugas de información vía Referer.

Evidencia:

Header ausente en respuesta de `http://localhost:3000`

Recomendación: Agregar el header Content-Security-Policy en `next.config.ts` usando la propiedad `headers()`. Para Next.js 16 ver documentación oficial.

Referencia normativa: Ley 21.719 Art. 24 · ISO 27001 A.14

CWE: CWE-693: Protection Mechanism Failure

#16 HDR-PERMISSIONS_POLICY

MEDIA

NO CUMPLE

Header HTTP: Permissions-Policy

Categoría: Headers HTTP

Descripción: El header Permissions-Policy NO está presente en las respuestas HTTP. Esto expone la aplicación a ataques como clickjacking, MIME-sniffing, o fugas de información vía Referer.

Evidencia:

Header ausente en respuesta de `http://localhost:3000`

Recomendación: Agregar el header Permissions-Policy en `next.config.ts` usando la propiedad `headers()`. Para Next.js 16 ver documentación oficial.

Referencia normativa: OWASP A05:2021

CWE: CWE-693: Protection Mechanism Failure

#17 HDR-REFERRER_POLICY

MEDIA

NO CUMPLE

Header HTTP: Referrer-Policy

Categoría: Headers HTTP

Descripción: El header Referrer-Policy NO está presente en las respuestas HTTP. Esto expone la aplicación a ataques como clickjacking, MIME-sniffing, o fugas de información vía Referer.

Evidencia:

Header ausente en respuesta de `http://localhost:3000`

Recomendación: Agregar el header Referrer-Policy en `next.config.ts` usando la propiedad `headers()`. Para Next.js 16 ver documentación oficial.

Referencia normativa: Ley 19.628 Art. 9

CWE: CWE-693: Protection Mechanism Failure

#18 HDR-STRICT_TRANSPORT_SECURITY

MEDIA

NO CUMPLE

Header HTTP: Strict-Transport-Security (HSTS)

Categoría: Headers HTTP

Descripción: El header Strict-Transport-Security (HSTS) NO está presente en las respuestas HTTP. Esto expone la aplicación a ataques como clickjacking, MIME-sniffing, o fugas de información vía Referer.

Evidencia:

Header ausente en respuesta de `http://localhost:3000`

Recomendación: Agregar el header Strict-Transport-Security (HSTS) en `next.config.ts` usando la propiedad `headers()`. Para Next.js 16 ver documentación oficial.

Referencia normativa: ISO 27001 A.10 · NIST CSF PR.AC-1

CWE: CWE-693: Protection Mechanism Failure

#19 HDR-X_CONTENT_TYPE_OPTIONS

MEDIA

NO CUMPLE

Header HTTP: X-Content-Type-Options

Categoría: Headers HTTP

Descripción: El header X-Content-Type-Options NO está presente en las respuestas HTTP. Esto expone la aplicación a ataques como clickjacking, MIME-sniffing, o fugas de información vía Referer.

Evidencia:

Header ausente en respuesta de `http://localhost:3000`

Recomendación: Agregar el header X-Content-Type-Options en `next.config.ts` usando la propiedad `headers()`. Para Next.js 16 ver documentación oficial.

Referencia normativa: OWASP A05:2021

CWE: CWE-693: Protection Mechanism Failure

#20 HDR-X_FRAME_OPTIONS

MEDIA

NO CUMPLE

Header HTTP: X-Frame-Options (Clickjacking)

Categoría: Headers HTTP

Descripción: El header X-Frame-Options (Clickjacking) NO está presente en las respuestas HTTP. Esto expone la aplicación a ataques como clickjacking, MIME-sniffing, o fugas de información vía Referer.

Evidencia:

Header ausente en respuesta de `http://localhost:3000`

Recomendación: Agregar el header X-Frame-Options (Clickjacking) en `next.config.ts` usando la propiedad `headers()`. Para Next.js 16 ver documentación oficial.

Referencia normativa: OWASP A05:2021 · IEC 62443

CWE: CWE-693: Protection Mechanism Failure

#21 DATA_DB_VESSEL_RECORDS**BAJA****PARCIAL****Tratamiento de datos personales: prisma/schema.prisma**

Categoría: Protección de Datos

Descripción: Se procesan los siguientes datos personales: operator (línea naviera). Base legal: Datos de operación portuaria — no son datos personales. Falta implementar: (1) política de retención, (2) derecho de acceso/rectificación/cancelación (ARCO), (3) consentimiento explícito documentado, (4) registro de tratamiento ante el Registro de Bases de Datos (CPPD).

Evidencia:

Datos: operator (línea naviera)

Base legal: Datos de operación portuaria — no son datos personales

Recomendación: Para producción: (1) Documentar el tratamiento en un Registro de Actividades de Tratamiento (RAT). (2) Implementar derechos ARCO mediante endpoint /api/privacy/* (acceso, rectificación, supresión, portabilidad). (3) Definir política de retención: logs de auditoría 5 años, sesiones 30 días. (4) Nombrar un Encargado de Protección de Datos si se supera el umbral de la ley.

Referencia normativa: Ley 19.628 Art. 2, 4, 9 · Ley 21.719 Art. 24

#22 DATA_OPERATION_LOG**BAJA****PARCIAL****Tratamiento de datos personales: prisma/schema.prisma**

Categoría: Protección de Datos

Descripción: Se procesan los siguientes datos personales: operator. Base legal: Cumplimiento de obligaciones legales (Art. 4 Ley 19.628 — auditoría). Falta implementar: (1) política de retención, (2) derecho de acceso/rectificación/cancelación (ARCO), (3) consentimiento explícito documentado, (4) registro de tratamiento ante el Registro de Bases de Datos (CPPD).

Evidencia:

Datos: operator

Base legal: Cumplimiento de obligaciones legales (Art. 4 Ley 19.628 — auditoría)

Recomendación: Para producción: (1) Documentar el tratamiento en un Registro de Actividades de Tratamiento (RAT). (2) Implementar derechos ARCO mediante endpoint /api/privacy/* (acceso, rectificación, supresión, portabilidad). (3) Definir política de retención: logs de auditoría 5 años, sesiones 30 días. (4) Nombrar un Encargado de Protección de Datos si se supera el umbral de la ley.

Referencia normativa: Ley 19.628 Art. 2, 4, 9 · Ley 21.719 Art. 24

#23 CS_INCIDENT_LOGGING**INFO****CUMPLE****Registro de eventos de seguridad**

Categoría: Ley 21.719 (Ciberseguridad)

Descripción: El sistema implementa un modelo OperationLog que registra eventos relevantes (chat, alertas, arribos) con timestamp y operador. Esto cumple con el requisito de trazabilidad.

Evidencia:

Evidencia: Tabla OperationLog en schema.prisma con campos type, severity, description, operator, metadata

Recomendación: Ampliar el logging para incluir eventos de seguridad específicos: intentos de login fallidos, accesos a endpoints sensibles, cambios de configuración. Implementar SIEM (Wazuh, Elastic SIEM) para correlación y alertas.

Referencia normativa: Ley 21.719 Art. 24 · ISO 27001 A.12.4 · NIST CSF DE.AE

#24 DEP_AUDIT

INFO

CUMPLE

Vulnerabilidades en dependencias

Categoría: Dependencias

Descripción: No se detectaron vulnerabilidades conocidas en las dependencias instaladas.

Evidencia:

bun audit OK – sin hallazgos

Recomendación: Mantener dependencias actualizadas. Configurar Snyk/Dependabot en GitHub para alertas automáticas de nuevas vulnerabilidades.

Referencia normativa: Ley 21.719 Art. 24 · OWASP A06:2021 (Vulnerable Components) · ISO 27001 A.12.6

#25 HDR_SERVER

INFO

CUMPLE

Header Server (Information Disclosure)

Categoría: Headers HTTP

Descripción: El header Server no revela información sensible.

Evidencia:

Header ausente o genérico

Recomendación: Configurar el servidor para no revelar versión ni software específico.

Referencia normativa: ISO 27001 A.13 · OWASP A05:2021

#26 SECRET_NONE

INFO

CUMPLE

Sin secretos hardcodeados

Categoría: Código Fuente

Descripción: No se detectaron patrones de secretos hardcodeados (API keys, contraseñas, JWT secrets, llaves SSH) en el código fuente del proyecto.

Evidencia:

Escaneo de 4 directorios completado sin hallazgos.

Recomendación: Mantener esta práctica. Considerar agregar pre-commit hooks con gitleaks/trufflehog para prevenir exposición accidental futura.

Referencia normativa: Ley 21.719 Art. 24 · Ley 19.628 Art. 9

3. Plan de Remediación Priorizado

El siguiente plan de remediación organiza los hallazgos por prioridad de acción, considerando la severidad y la dependencia técnica entre soluciones. Las acciones están agrupadas en tres horizontes temporales: inmediato (≤ 7 días), corto plazo (≤ 30 días) y mediano plazo (≤ 90 días).

3.1 Acciones Inmediatas (≤ 7 días)

- Implementar autenticación real OAuth 2.0 con NextAuth.js (providers Microsoft Azure AD y Google Workspace) — elimina el hallazgo AUTH_REAL_OAUTH (crítico).
- Agregar middleware de Next.js que valide sesión en TODAS las rutas /api/* excepto /api/auth — cierra los hallazgos API_REPORTS_NO_AUTH y API_CHAT_NO_AUTH (altos).
- Implementar rate limiting en APIs con upstash/ratelimit (60 req/min operacional, 10 req/min para LLM) — cierra API_NO_RATE_LIMIT (alto).
- Configurar HTTPS con certificado válido (Let's Encrypt o EV) en producción, con redirección HTTP→HTTPS obligatoria — cierra DATA_TLS (alto).
- Establecer canal de notificación a ANCI conforme al Art. 16 de la Ley 21.719 (3 horas máximo desde detección) — cierra CS_INCIDENT_NOTIFICATION (crítico).
- Cifrar la base de datos: migrar a PostgreSQL con pgcrypto para datos sensibles + LUKS en disco — cierra DATA_ENCRYPTION_AT_REST (alto).

3.2 Acciones a Corto Plazo (≤ 30 días)

- Configurar TODOS los headers HTTP de seguridad en next.config.ts: Content-Security-Policy, Strict-Transport-Security (max-age=63072000, includeSubDomains), X-Frame-Options: DENY, X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, Permissions-Policy restrictivo.
- Implementar gestión formal de secretos con variables de entorno + rotation policy. Verificar con pre-commit hooks (gitleaks/trufflehog) que ningún secreto se cometa al repositorio.
- Establecer procedimiento formal de respuesta a incidentes (CSIRT) con roles RACI: Incident Commander, SOC Analyst, Comunicaciones, Legal, Directemar liaison.
- Realizar evaluación formal de riesgos cibernéticos (ISO 27005 / NIST SP 800-30): inventario de activos, matriz de amenazas, cálculo probabilidad $\times$ impacto.
- Implementar backups automatizados: DB snapshots diarios (retención 30 días) + replicación geográfica + pruebas trimestrales de restauración. RTO $\leq 4h$, RPO $\leq 1h$.
- Implementar segmentación de redes OT/IT con firewall industrial. Deny-by-default. Solo NTP/SNMPv3/RTSP permitidos entre zona OT y VTS.
- Documentar el Registro de Actividades de Tratamiento (RAT) conforme a la Ley 19.628: datos personales procesados, base legal, retención, destinatarios.
- Configurar SIEM (Wazuh o Elastic SIEM) para correlación de eventos de seguridad y alertas en tiempo real.

3.3 Acciones a Mediano Plazo (≤ 90 días)

- Implementar derechos ARCO (Acceso, Rectificación, Cancelación, Oposición) mediante endpoints /api/privacy/* con autenticación obligatoria.
- Nombrar formalmente un Encargado de Protección de Datos (DPO) y registrarlo ante la CPPD si se superan los umbrales de la Ley 19.628.
- Realizar auditoría formal ISO/IEC 27001 con entidad acreditada (Bureau Veritas, SGS, TÜV) para obtener certificación.
- Realizar auditoría IEC 62443 con foco en sistemas industriales (radares, AIS, cámaras IP).
- Establecer ejercicios simulacros de incidente cibernético al menos 2 veces al año, con participación de Directemar y ANCI.
- Implementar SCA (Software Composition Analysis) automatizado con Snyk o Dependabot en CI/CD para detectar vulnerabilidades en dependencias.
- Obtener calificación A+ en SSL Labs para la configuración TLS del dominio.
- Documentar y certificar formalmente ante Directemar el cumplimiento de los Reglamentos CONAMAR y el DS MOPT 1/1941.

4. Conclusiones y Recomendaciones Finales

El prototipo del sistema MaritimeVTS para TCP Valparaíso, en su estado actual, alcanza un índice de cumplimiento del 15% respecto al conjunto normativo evaluado (Ley 21.719, Ley 19.628, OWASP Top 10, ISO 27001, IEC 62443, NIST CSF 2.0, IMO MSC.428(98)). Este nivel es consistente con un prototipo en fase de demostración, donde se priorizó la validación de conceptos operacionales (fusión AIS/Radar/CCTV con IA, dashboard ejecutivo, generación de informes en múltiples formatos, asistente IA con triple fuente de información) por encima de la madurez de seguridad.

Sin embargo, antes de cualquier despliegue en un entorno operacional real, incluyendo pruebas piloto con Directemar, deben resolverse obligatoriamente los hallazgos de severidad **crítica** y **alta**, dado que representan violaciones directas a la normativa chilena vigente y expondrían al operador del puerto y a la Autoridad Marítima a riesgos legales, operacionales y reputacionales.

Las fortalezas identificadas en el prototipo incluyen: (1) ausencia de secretos hardcodeados en el código fuente, (2) ausencia de funciones peligrosas como `eval()` o `innerHTML`, (3) implementación del modelo `OperationLog` para trazabilidad de eventos (cumplimiento parcial ISO 27001 A.12.4), y (4) uso consistente de TypeScript con ESLint para reducir clases de bugs. Estas prácticas deben mantenerse y reforzarse en el desarrollo del producto real.

Recomendación final: antes de avanzar a producción, ejecutar una segunda auditoría independiente con una firma especializada (Bureau Veritas, EY, PwC, KPMG o similar) y obtener certificación formal ISO/IEC 27001:2022 y, en paralelo, iniciar el proceso de declaración como Operador de Importancia Vital (OIV) ante la Agencia Nacional de Ciberseguridad (ANCI) conforme al Art. 16 de la Ley 21.719. Esto posicionará al sistema VTS de TCP Valparaíso como referente regional en gestión de tráfico marítimo con cumplimiento normativo de clase mundial.

Documento generado automáticamente por el script de auditoría
MaritimeVTS Security Audit Script v1.0 · 2026-10-01T01:58:45.580Z
Objetivo: <http://localhost:3000>